

InsureWell — Authentication with Microsoft Entra ID

Change documentation · React 18 SPA + Spring Boot 3.1 API

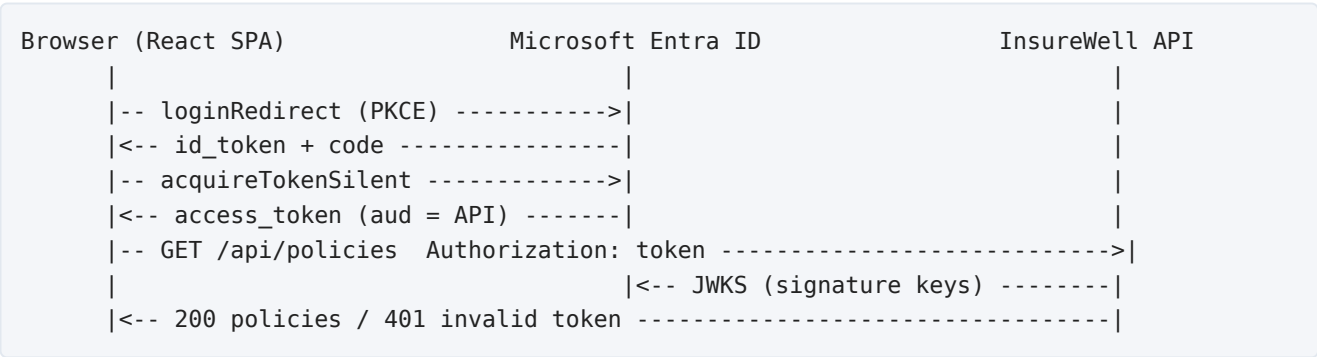
Issue: “Implement Authentication with Azure AD” — use Microsoft Entra ID and the latest Microsoft Identity features.

1. Summary of the change

InsureWell now authenticates users with **Microsoft Entra ID** (formerly Azure AD) on the Microsoft identity platform v2.0 endpoint. The React SPA signs users in with **MSAL** (`@azure/msal-browser` and `@azure/msal-react`) using the authorization code flow with PKCE, and attaches the resulting access token to every API call. The Spring Boot API is an **OAuth 2.0 resource server** that validates the token signature against the tenant JWKS endpoint and checks the issuer and audience claims before serving policy or claim data.

- No passwords, secrets or tokens are stored by InsureWell; tokens live in `sessionStorage` only.
- App roles (`roles`) and delegated scopes (`scp`) are mapped to Spring Security authorities, ready for fine-grained authorisation.
- Authentication is configuration-driven: with no tenant configured the app keeps running unauthenticated for local development against the seeded H2 data.

2. Authentication flow



3. Backend changes (Spring Boot 3.1, Java 17)

File	Purpose
<code>security/SecurityConfig.java</code>	Stateless filter chain, CORS, public endpoints, resource-server JWT configuration.

<code>security/EntraIdProperties.java</code>	Binds <code>insurewell.security.*</code> ; derives issuer and JWKS URIs and accepted audiences.
<code>security/AudienceValidator.java</code>	Rejects tokens issued for another API (<code>aud</code> claim check).
<code>security/EntraIdAuthoritiesConverter.java</code>	Maps roles to <code>ROLE_*</code> and <code>scp</code> to <code>SCOPE_*</code> authorities.
<code>controller/UserController.java</code>	New <code>GET /api/me</code> endpoint returning the caller's identity claims.
<code>pom.xml</code>	Adds <code>spring-boot-starter-oauth2-resource-server</code> and <code>spring-security-test</code> .

Endpoint protection

Endpoint	Access
<code>GET /api</code> , <code>GET /api/health</code>	Anonymous (discovery and monitoring)
<code>/api/policies/**</code> , <code>/api/claims/**</code> , <code>/api/me</code>	Valid Entra ID access token required

Configuration

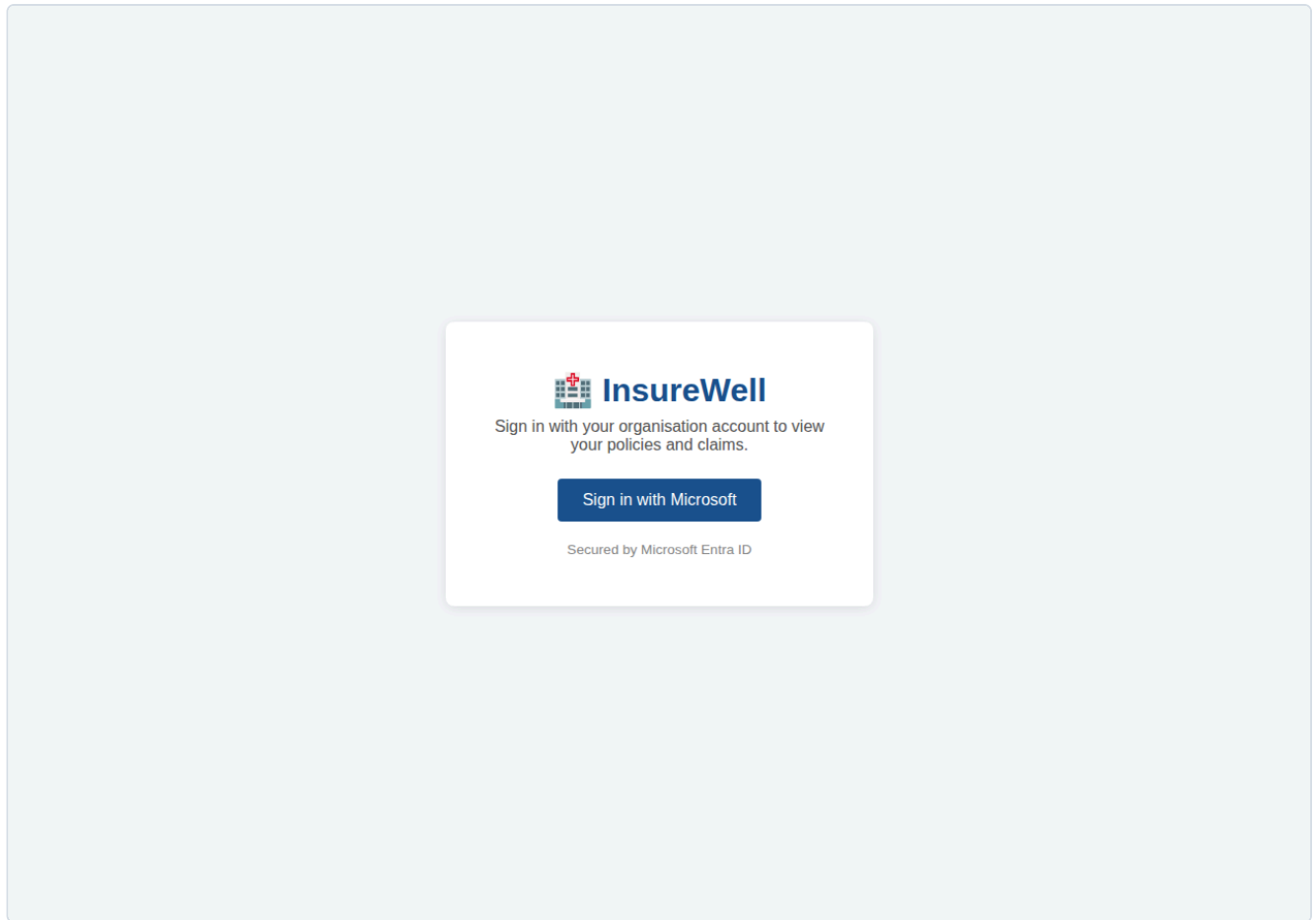
Property	Environment variable	Description
<code>insurewell.security.mode</code>	<code>INSUREWELL_SECURITY_MODE</code>	<code>auto</code> (default), <code>on</code> , <code>off</code>
<code>insurewell.security.tenant-id</code>	<code>AZURE_TENANT_ID</code>	Directory (tenant) id
<code>insurewell.security.client-id</code>	<code>AZURE_CLIENT_ID</code>	API application (client) id — expected audience
<code>insurewell.security.instance</code>	<code>AZURE_CLOUD_INSTANCE</code>	Cloud authority, default <code>https://login.microsoftonline.com</code>
<code>insurewell.security.allowed-origins</code>	<code>CORS_ALLOWED_ORIGINS</code>	Browser origins allowed to call the API

4. Frontend changes (React 18 + MSAL)

File	Purpose
src/authConfig.js	MSAL configuration (authority, redirect URI, sessionStorage cache) and API scope.
src/apiClient.js	Axios instance that acquires a token silently and adds the authorization header; falls back to a redirect when interaction is required.
src/index.js	Initialises MSAL, handles the redirect response, sets the active account and wraps the app in <code>MsalProvider</code> .
src/components/SignIn.js	Sign-in screen shown to unauthenticated users.
src/components/UserMenu.js	Signed-in user name and sign-out action in the navigation bar.
src/App.js , Dashboard.js , Claims.js	All API traffic routed through the authenticated client; 401/403 responses surface a clear message.
.env.example	Template for the SPA app-registration settings.

```
REACT_APP_AZURE_TENANT_ID=<tenant-id>
REACT_APP_AZURE_CLIENT_ID=<spa-client-id>
REACT_APP_AZURE_API_SCOPE=api://<backend-client-id>/access_as_user
```

5. UI screens



Screen 1 — Sign in. When Entra ID is configured, unauthenticated users see the sign-in screen; “Sign in with Microsoft” starts the MSAL redirect flow to the Microsoft identity platform.

 InsureWell

DashboardClaims

Policy Dashboard

3 policies on your account

Alex JohnsonPOL-2024-001

Maria GarciaPOL-2024-002

David ChenPOL-2023-009

InsureWell Premium Health Plan

Policy ID: POL-2024-001

Coverage Amount

\$250,000

Policy Holder

Alex Johnson

Start Date

2024-01-01

End Date

2026-12-31

ACTIVE

4

Total Claims

2

Pending

2

Approved

\$6,100

Total Claimed

Recent Claims

Claim ID	Description	Amount	Status	Submitted
CLM-17210418000000	X-ray imaging for dental work	\$750	Pending	7/15/2024
CLM-17201700000000	Physical therapy sessions (10 sessions)	\$3,000	Pending	7/5/2024
CLM-17162160000000	Lab tests and blood work	\$850	Approved	5/20/2024
CLM-17157870000000	Doctor visit for annual checkup	\$1,500	Approved	5/15/2024

Screen 2 — Policy dashboard. After sign-in the dashboard loads policies through the authenticated API client; the navigation bar shows the signed-in user and a sign-out action.

Claims

Submit and track your insurance claims

[+ New Claim](#)

Submitted Claims

Filter by policy: All Policies

7 claims

Claim ID	Policy	Description	Amount	Status	Submitted	Action
CLM-1721041800000	POL-2024-001	X-ray imaging for dental work	\$750	Pending	7/15/2024	
CLM-1720598400000	POL-2024-002	Dental cleaning and checkup	\$1,200	Rejected	7/10/2024	
CLM-1720170000000	POL-2024-001	Physical therapy sessions (10 sessions)	\$3,000	Pending	7/5/2024	
CLM-1717955400000	POL-2024-002	Prescription medications	\$500	Approved	6/10/2024	
CLM-1717264800000	POL-2024-002	Emergency room visit	\$2,200	Pending	6/1/2024	
CLM-1716216600000	POL-2024-001	Lab tests and blood work	\$850	Approved	5/20/2024	
CLM-1715787000000	POL-2024-001	Doctor visit for annual checkup	\$1,500	Approved	5/15/2024	

Screen 3 — Claims. Claim submission and status updates carry the same access token, so the API can authorise each operation.

6. Verification

- `SecurityEnabledTest` — public health endpoint stays open, policies/claims/me return **401** without a token, and /api/me returns the token claims with one.
- `SecurityDisabledTest` — with `mode=off` the API stays open for local development.
- `EntraIdSecurityUnitTest` — audience validation, issuer/JWKS URI derivation and role/scope mapping.
- Manual run: with tenant and client id set, `GET /api/policies` returned **401** with a `WWW-Authenticate` challenge; without them the seeded data still loads.
- Frontend production build compiles successfully with and without the Entra ID environment variables.

7. Entra ID app registration checklist

- Register an **API** application; expose a scope such as `access_as_user`.
- Register the **SPA** application with platform “Single-page application” and redirect URI `http://localhost:3000` (plus the deployed origin).
- Grant the SPA delegated permission to the API scope and admin-consent it.

- Optionally define app roles (for example `Claims.Approve`) — they arrive as `ROLE_*` authorities.
- Set the backend and frontend environment variables listed above.